

Security+ 5.2 · Risk Analysis

Mestre CyberSec · Aula 5.2 — Risk Analysis (9:13) · [Assistir Vídeo no YouTube](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Análise: qualitativa (alto/médio/baixo) vs quantitativa ($\$ - SLE \times ARO = ALE$); risk appetite (o que a organização ACEITA — board define); risk tolerance (variação aceitável por área); risk register.

💡 Highlights que a prova CompTIA cobra

- $ALE = SLE \text{ (perda por incidente)} \times ARO \text{ (vezes/ano)}$ — o quantitativo
- Appetite: o RISCO que aceita; tolerance: variação por área (operacional)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'accepting a specific risk level per business unit'=risk tolerance

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Expectativa de Perda Única (SLE)

O valor monetário esperado de uma única ocorrência de um evento de risco. Calculado como Valor do Ativo × Fator de Exposição (EF).

⚠ **Armadilha CompTIA:** SLE is NOT annualized — it is per-incident. If the question says 'per occurrence' or 'one event', it's SLE, not ALE.

• Taxa de Ocorrência Anualizada (ARO)

A frequência estimada com que uma ameaça deve ocorrer em um único ano (ex.: 0,5 = uma vez a cada 2 anos, 4 = quatro vezes ao ano).

⚠ **Armadilha CompTIA:** ARO can be a fraction. If a flood happens 'once every 5 years', ARO = 0.2 — this directly multiplies into the ALE formula.

• Expectativa de Perda Anualizada (ALE)

A perda monetária esperada de um risco ao longo de um ano. Fórmula: $ALE = SLE \times ARO$. Usada para justificar custos de controles de segurança na análise de custo/benefício.

⚠ **Armadilha CompTIA:** $ALE = SLE \times ARO$ is the only formula to memorize for the exam. If a control costs less than the ALE, it is generally worth implementing.

• Análise Qualitativa de Risco (N/A)

Uma avaliação de risco subjetiva e baseada em cenários que usa classificações como alto/médio/baixo ou vermelho/amarelo/verde em vez de valores monetários; baseia-se no julgamento de especialistas.

⚠ **Armadilha CompTIA:** If the question mentions 'high/medium/low' or 'scenario-based' or 'subjective rating', it is qualitative — not quantitative. It does NOT produce dollar amounts.

• Análise Quantitativa de Risco (N/A)

Uma avaliação de risco objetiva e numérica que atribui valores em dólares ao risco usando os cálculos de SLE, ARO e ALE.

⚠ **Armadilha CompTIA:** Any question showing actual dollar/currency values or asking you to calculate SLE, ARO, or ALE is quantitative. Hard data vs. soft ratings is the key distinction.

• Appetite ao Risco (N/A)

A quantidade e o tipo geral de risco que a organização está disposta a aceitar na busca de seus objetivos, definido no nível do conselho/diretoria.

⚠ **Armadilha CompTIA:** Appetite is set by the BOARD/senior leadership — it is the BROAD, organizational-level statement of acceptable risk (e.g., 'we will not accept risks that could cause bankruptcy').

• Tolerância ao Risco (N/A)

A variação aceitável em relação ao apetite ao risco, geralmente definida por unidade de negócio, departamento ou sistema; mais granular e tática que o apetite.

⚠ **Armadilha CompTIA:** Exam phrase trigger: 'accepting a specific risk level per business unit' = risk TOLERANCE. Appetite = organization-wide, Tolerance = per business unit/department.

• Registro de Riscos (N/A)

Um documento ou repositório central que lista os riscos identificados, sua probabilidade, impacto, responsável, status de mitigação e nível de risco residual.

⚠ **Armadilha CompTIA:** The risk register is the OUTPUT of the risk identification process and the input to ongoing risk monitoring. Know that it tracks ownership and mitigation progress.

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa de serviços financeiros está realizando uma análise quantitativa de risco para seu banco de dados de clientes. O banco de dados está avaliado em US\$ 500.000. Uma violação bem-sucedida exporia 20% dos registros, e dados do setor indicam que esse evento é esperado uma vez a cada quatro anos. Qual é a perda anual esperada (ALE)?

- A) US\$ 25.000
- B) US\$ 100.000
- C) US\$ 125.000
- D) US\$ 500.000

QUESTÃO 2 · CENÁRIO DE EXAME

Um analista de risco está calculando a expectativa de perda única (SLE) para um servidor de folha de pagamento. O servidor tem valor de ativo de US\$ 120.000. Se um ataque ransomware for bem-sucedido, a equipe estima que 35% do valor do servidor seria perdido. Qual é a SLE?

- A) US\$ 78.000
- B) US\$ 42.000
- C) US\$ 120.000
- D) US\$ 155.000

QUESTÃO 3 · CENÁRIO DE EXAME

Uma pequena startup não tem dados históricos confiáveis de perdas e precisa priorizar riscos de segurança cibernética rapidamente. O CISO pede que a equipe classifique cada risco como alto, médio ou baixo com base em probabilidade e impacto usando um mapa de calor. Que tipo de análise de risco está sendo usada?

- A) Análise de perda anual esperada
- B) Análise de impacto nos negócios
- C) Análise qualitativa de risco
- D) Análise quantitativa de risco

QUESTÃO 4 · CENÁRIO DE EXAME

O conselho de administração declara que a organização está disposta a aceitar risco moderado para acelerar a adoção da nuvem, mas não aceitará risco que possa afetar dados de segurança de pacientes. O que essa declaração define principalmente?

- A) Tolerância a risco
- B) Registro de riscos
- C) Expectativa de perda única
- D) Apetite a risco

QUESTÃO 5 · CENÁRIO DE EXAME

Uma empresa tem apetite a risco geral moderado. No entanto, sua plataforma de comércio eletrônico não pode ficar indisponível por mais de 15 minutos, enquanto o sistema interno de RH pode ficar fora do ar por até 4 horas. O que essa diferença ilustra?

- A) Apetite a risco
- B) Tolerância a risco
- C) Taxa anual de ocorrência
- D) Fator de exposição

QUESTÃO 6 · CENÁRIO DE EXAME

Após concluir uma avaliação de risco, um analista de GRC precisa documentar cada risco identificado, seu proprietário, probabilidade, impacto, pontuação, plano de tratamento e status atual. Onde essas informações devem ser registradas?

- A) Inventário de ativos
- B) Relatório de varredura de vulnerabilidades
- C) Registro de riscos
- D) Acordo de nível de serviço

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa calcula que um ataque a aplicação web tem SLE de US\$ 50.000 e ARO de 2,0, produzindo um ALE de US\$ 100.000. Após implementar um firewall de aplicação web, o ARO é reduzido para 0,5 enquanto o SLE permanece US\$ 50.000. Qual é a redução da perda anual esperada?

- A) US\$ 75.000
- B) US\$ 25.000
- C) US\$ 50.000
- D) US\$ 100.000

QUESTÃO 8 · CENÁRIO DE EXAME

Um hospital deseja justificar gastos com segurança cibernética estimando a perda monetária anual esperada por ransomware. A equipe tem registros internos de incidentes e dados do setor sobre custos de violações. Qual abordagem melhor se ajusta a esse requisito?

- A) Análise qualitativa de risco
- B) Definição de apetite a risco
- C) Manutenção do registro de riscos
- D) Análise quantitativa de risco

QUESTÃO 9 · CENÁRIO DE EXAME

Um analista de risco está calculando a taxa anual de ocorrência (ARO) para uma inundação que dados históricos indicam acontecer uma vez a cada 20 anos. Qual ARO deve ser usado?

- A) 0,20
- B) 0,05
- C) 5,0
- D) 20,0

QUESTÃO 10 · CENÁRIO DE EXAME

Uma empresa identifica um achado de alto risco em seu portal do cliente. A equipe implementa um controle compensatório, reduzindo o risco a um nível residual baixo que a gestão aceita. O que o analista de risco deve fazer em seguida?

- A) Atualizar o registro de riscos com o risco residual, tratamento e status de aceitação
- B) Remover o risco do registro de riscos porque um controle foi implementado
- C) Encerrar o relatório de varredura de vulnerabilidades sem documentar a decisão
- D) Alterar o apetite a risco para corresponder ao nível de risco residual

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — US\$ 25.000

$SLE = \text{valor do ativo} \times \text{fator de exposição} = \text{US\$ } 500.000 \times 0,20 = \text{US\$ } 100.000$. $ARO = 1 \text{ evento} / 4 \text{ anos} = 0,25$. $ALE = SLE \times ARO = \text{US\$ } 100.000 \times 0,25 = \text{US\$ } 25.000$.

Questão 2: Alternativa B — US\$ 42.000

$SLE = \text{valor do ativo} \times \text{fator de exposição}$. Aqui, $\text{US\$ } 120.000 \times 0,35 = \text{US\$ } 42.000$. Os outros valores não aplicam corretamente o fator de exposição.

Questão 3: Alternativa C — Análise qualitativa de risco

A análise qualitativa de risco usa classificações subjetivas como alto, médio e baixo, frequentemente com um mapa de calor, quando dados numéricos ou tempo são limitados. A análise quantitativa usa valores monetários e cálculos como SLE, ARO e ALE. A análise de impacto nos negócios concentra-se em funções críticas de negócio e requisitos de recuperação.

Questão 4: Alternativa D — Apetite a risco

Apetite a risco é a quantidade e o tipo gerais de risco que a organização está disposta a aceitar, e normalmente é definido pela alta liderança ou pelo conselho. Tolerância a risco é a variação aceitável em torno desse apetite para áreas ou sistemas específicos.

Questão 5: Alternativa B — Tolerância a risco

Tolerância a risco é o desvio aceitável do apetite a risco geral para um sistema, departamento ou processo específico. A empresa aceita risco moderado em geral, mas tolera níveis diferentes de risco de disponibilidade para sistemas diferentes.

Questão 6: Alternativa C — Registro de riscos

O registro de riscos é o registro central usado para acompanhar riscos identificados, proprietários, classificações, decisões de tratamento e status. O inventário de ativos lista ativos, relatórios de vulnerabilidades listam achados técnicos e SLAs definem compromissos de serviço.

Questão 7: Alternativa A — US\$ 75.000

Antes do controle, $ALE = \text{US\$ } 50.000 \times 2,0 = \text{US\$ } 100.000$. Após o controle, $ALE = \text{US\$ } 50.000 \times 0,5 = \text{US\$ } 25.000$. A redução é $\text{US\$ } 100.000 - \text{US\$ } 25.000 = \text{US\$ } 75.000$.

Questão 8: Alternativa D — Análise quantitativa de risco

A análise quantitativa de risco usa dados numéricos e monetários, como SLE, ARO e ALE, para estimar a perda anual esperada. Isso é apropriado quando dados históricos e do setor estão disponíveis e a justificativa orçamentária exige valores financeiros.

Questão 9: Alternativa B — 0,05

ARO é a frequência esperada por ano. Se um evento acontece uma vez a cada 20 anos, $ARO = 1 / 20 = 0,05$.

Questão 10: Alternativa A — Atualizar o registro de riscos com o risco residual, tratamento e status de aceitação

O registro de riscos deve ser atualizado para refletir o tratamento aplicado, o nível de risco residual, o proprietário e a aceitação pela gestão. Riscos não são simplesmente excluídos após mitigação porque o risco residual e as decisões de aceitação ainda precisam ser acompanhados.